

7.

REQUIREMENT OVERVIEW

An overview of the 12 requirements in the PCI-DSS, before covering each in detail.



FUNDAMENTALS

FUNDAMENTALS REQUIREMENT OVERVIEW

The 12 requirements of PCI-DSS are (as of v4.0.0):

1. Install and Maintain Network Security Controls
2. Apply Secure Configurations to All System Components
3. Protect Stored Account Data
4. Protect Cardholder Data with Strong Cryptography During Transmission Over Open, Public Networks
5. Protect All Systems and Networks from Malicious Software
6. Develop and Maintain Secure Systems and Software
7. Restrict Access to System Components and Cardholder Data by Business Need to Know
8. Identify Users and Authenticate Access to System Components
9. Restrict Physical Access to Cardholder Data
10. Log and Monitor All Access to System Components and Cardholder Data
11. Test Security of Systems and Networks Regularly
12. Support Information Security with Organizational Policies and Programs

FUNDAMENTALS REQUIREMENT OVERVIEW

For practical use, in this course I'll use simplified names:

1. Keep a Firewall;
2. No Defaults;
3. Protect Stored Data;
4. Protect Transmitted Data;
5. Prevent Malware;
6. Develop Securely;
7. Need-to-Know Access;
8. Identify Access;
9. Restrict Physical Access;
10. Log Everything;
11. Test Regularly;
12. InfoSec Policy;



FUNDAMENTALS

REQUIREMENT OVERVIEW



1. KEEP A FIREWALL

Requirement 1 is all about having a proper firewall configuration, restricting unknown traffic, having a firewall on all machines, and using change management.



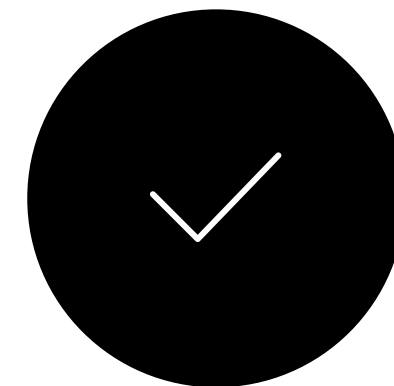
2. NO DEFAULTS

Requirement 2 is all about always changing default passwords and accounts, isolating servers, inventorying assets, and removing all unneeded functionality.



3. PROTECT STORED DATA

Requirement 3 is about limiting CHD storage to the essential, purging it, masking PANs, having proper key encryption and key lifecycle management.



4. PROTECT TRANSMITTED DATA

Requirement 4 is all about protecting CHD in transit, including using strong encryption, including for public wireless networks, as well as never sending plaintext PANs.



5. PREVENT MALWARE

Requirement 5 is about having proper AV software that is regularly updated, performs regular scans, outputs regular logs, and cannot be disabled individual users.

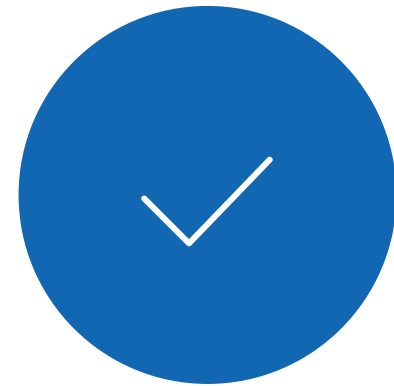


6. DEVELOP SECURELY

Requirement 6 is about securing both OTS software with risk ranking and patch installation, but also including security requirements in the SDLC and in dev training.

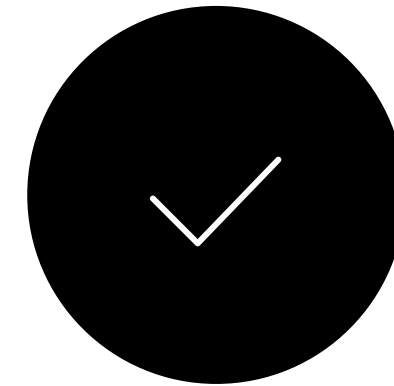
FUNDAMENTALS

REQUIREMENT OVERVIEW



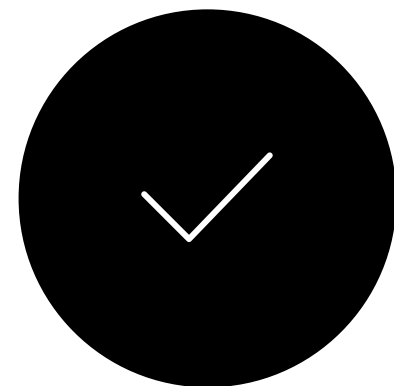
7. NEED-TO-KNOW ACCESS

Requirement 7 is all about the PoLP, or Principle of Least Privilege. Defining user roles with the least privilege possible, and using access control for systems/networks.



8. IDENTIFY ACCESS

Requirement 8 is about identifying specific users. Unique IDs, no shared users, strong authentication, MFA, not sharing physical access control devices, restricting DBs.



9. RESTRICT PHYSICAL ACCESS

Requirement 9 is about physical access. Entry control, visitor distinction and authorization, restricting physical access, and strict media storage/distribution, and training.



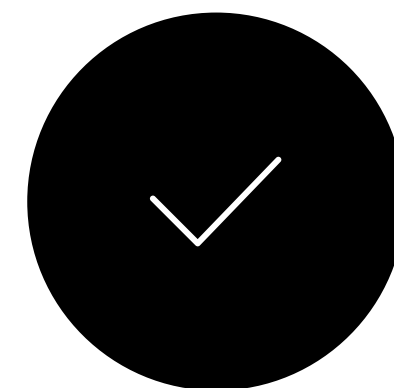
10. LOG EVERYTHING

Requirement 10 is about logging. Logging specific events and specific data elements, one time sync, log FIM, log retention, and immediate log alert responses.



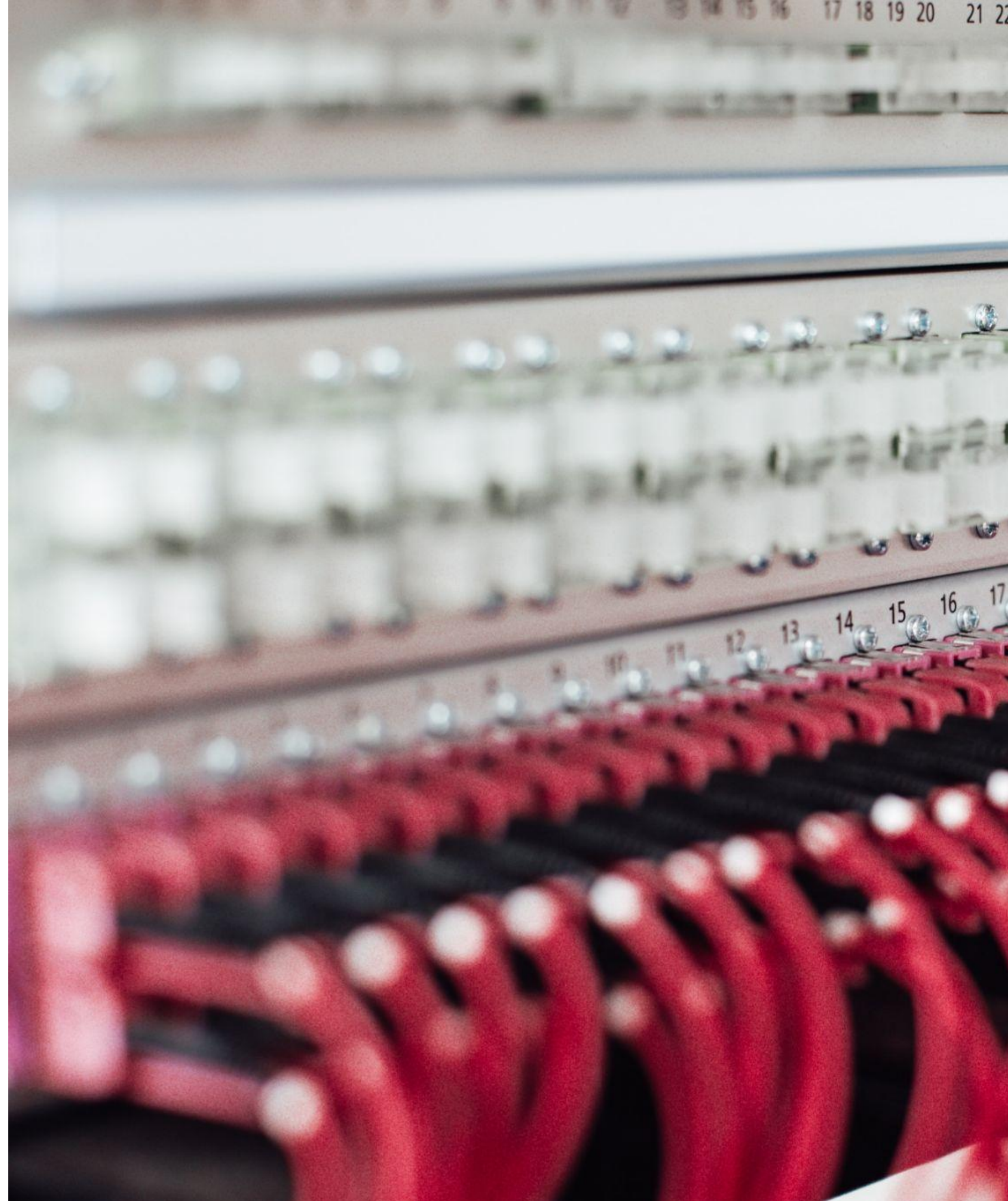
11. TEST REGULARLY

Requirement 11 is about vulnerability scanning, penetration testing, AP identification (legit and rogue), IDS/IPS systems, and FIM/change detection.



12. INFOSEC POLICY

Requirement 12 is the sum of all policies. Usage policies, incident response, risk assessment, employee screening, employee roles, responsibilities, awareness and training.



FUNDAMENTALS

FUNDAMENTALS REQUIREMENT OVERVIEW

Req. 1 (Keep a Firewall) is all about blocking access to the CDE through a firewall or other network security devices, and having clear rules for inbound/outbound traffic.

- Understanding the network topology and CHD data flows;
- Having firewalls, protective systems, good configurations;
- Also, minimizing traffic to the CDE to the essential;

Req. 2 (No Defaults) is, about not using defaults, such as vendor passwords, but more than that, it's about shutting down all obvious vulnerabilities;

- Not storing multiple functionality in one system;
- Disabling unnecessary features, ports, accounts;
- In short, not letting obvious vulnerabilities remain;

FUNDAMENTALS

REQUIREMENT OVERVIEW

Req. 3 (Protect Stored Data) is all about protecting stored card data at rest (truncating, tokenizing, encrypting, etc). The goal is that, even if the attacker obtains data, they can't see them:

- Effective key lifecycle (expiration, custodians) is required;
- Besides protecting data, minimizing the data you store also matters, as well as deleting data not needed anymore;

Req. 4 (Protect Transmitted Data) is simply about maintaining encryption of data when transmitting them in the the open:

- Strong authentication required (e.g., AES-256, 3DES);
- This not only includes WiFi but mobile, Bluetooth, or other communication modalities (WPA/WPA2 required);
- Never PANs as plaintext (masking them);





FUNDAMENTALS

FUNDAMENTALS REQUIREMENT OVERVIEW

Req. 5 (Prevent Malware) is all about preventing malware from entering.

- Having anti-malware software, having it frequently updated, having it scan regularly, having it protect against all types of threats;
- Having policies so individual users can't disable it, too;

Req 6 (Develop Securely) is all about mitigating vulnerabilities in both in-house and third-party software:

- Secure SW dev lifecycle + patching vulnerabilities quickly;
- One of the hardest (devs don't care about security);
- Besides initial deployment of apps, changes must be managed (rollback policies, etc);

FUNDAMENTALS

REQUIREMENT OVERVIEW

Req. 7 (Need-to-Know Access) is all about restrictive access control, both digital and physical.

- “Least privilege”. Each role sees the least card data, for the least amount of time, to do their job. If possible, nothing!;
- Having access control by roles to formally enforce this;

Req. 8 (Identify Access) is all about non-repudiation and accountability. If something happens, the “associated human” must be identified.

- Unique IDs, no group users, removing old accounts;
- Strong password practices, account lockups on X attempts;
- Strong authentication measures unique to the person (fobs, smart cards, etc), MFA for certain actions (e.g., admin);





FUNDAMENTALS

FUNDAMENTALS REQUIREMENT OVERVIEW

Req. 9 (Restrict Physical Access) is about limiting physical access to devices/people. CCTV, locked rooms, safes etc.

- Preventing both tampering with your devices (keyloggers, skimmers) or tampering with your people (social engineering);
- Also safe storage, transport, disposal of media w/ card data;

Req. 10 (Log Everything) is all about constant logging. If an attack occurs, we know when and where.

- Specific data must be stored, as well as specific events (actions on card data, admin actions, etc);;
- Time must be synchronized using one mechanism;
- FIM (File Integrity Management) on log files (no changes);

FUNDAMENTALS

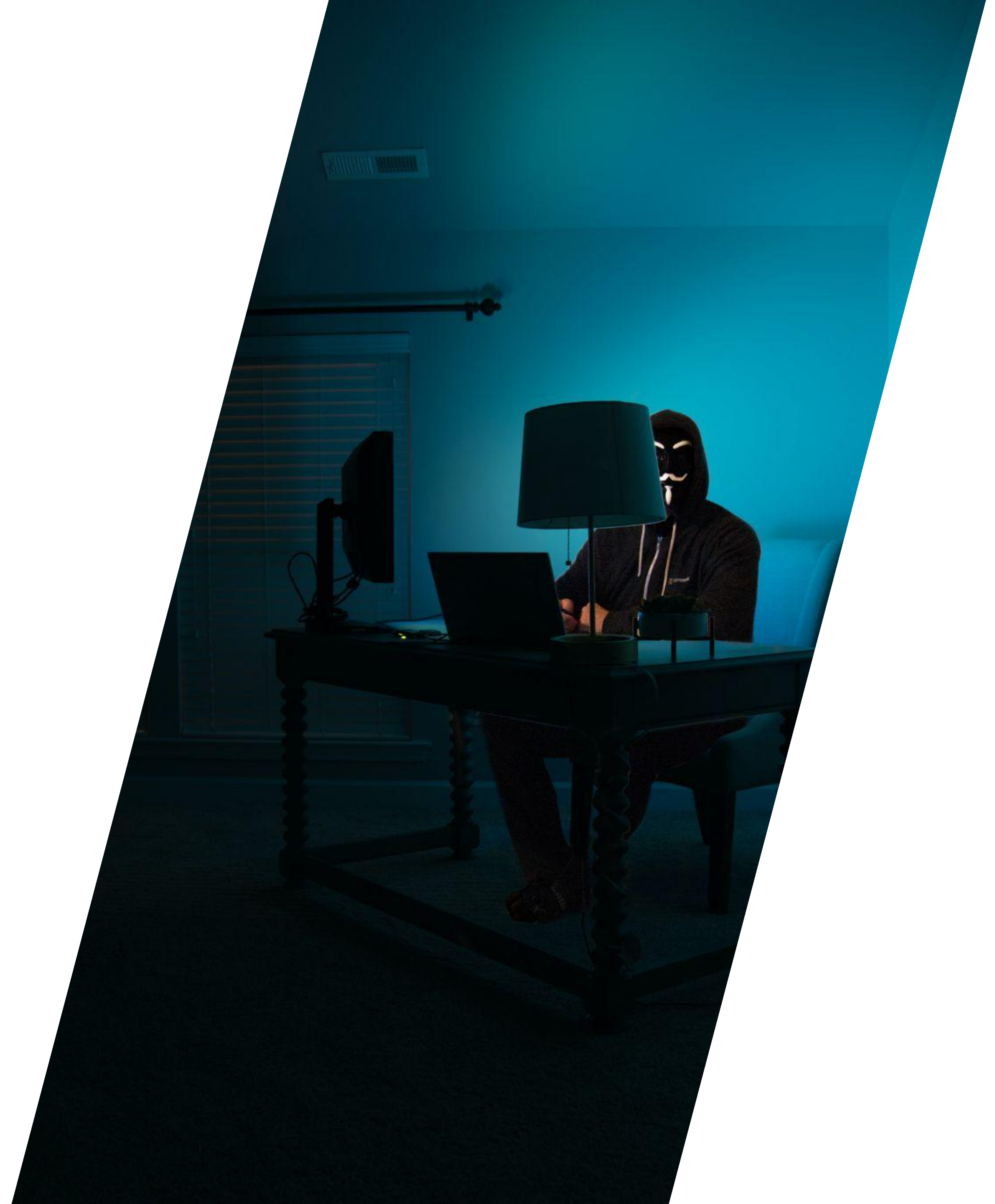
REQUIREMENT OVERVIEW

Req. 11 (Test Regularly) is about regular testing networks and systems to identify vulnerabilities:

- Both internal and external. AP audit (legit + rogue), penetration testing, vulnerability scanning;
- Knowing what all of your weak points are - and regularly;

Req. 12 (InfoSec Policy) is about having pervasive policies, for all types of security controls, at all levels:

- Touches all roles, all systems, all levels dealing with CHD;
- Tech usage policies (what tech, acceptable use, rules);
- Employee screening. Yearly BG checks, NDAs on CHD;
- Formal incident management procedures, yearly tested;





FUNDAMENTALS

FUNDAMENTALS REQUIREMENT OVERVIEW

The 12 requirements can seem complex to tackle. I use a personal mnemonic of 4 “Keep it” statements to simplify it:

- Keep It Locked
- Keep It Blocked
- Keep It Identified;
- Keep It Updated;

All of the 12 requirements will fit, in some way, in this mnemonic:

- Keep it Locked (safe, encrypted, secure data);
- Keep It Blocked (blocking vulnerabilities, access, malware);
- Keep it Identified (identifying accesses and users);
- Keep it Updated (updating systems, AV, software tests);

FUNDAMENTALS

REQUIREMENT OVERVIEW

We can easily match the requirements to this mnemonic:

- Req. 1 (Keep a Firewall): Keep It Blocked;
- Req. 2 (No Defaults): Keep It Blocked;
- Req 3. (Protect Stored Data): Keep it Locked;
- Req 4. (Protect Transmitted Data): Keep It Locked;
- Req 5. (Prevent Malware): Keep It Blocked;
- Req 6. (Develop Securely): Keep it Blocked;
- Req 7. (Need-to-Know Access): Keep it Blocked;
- Req 8. (Identify Access): Keep it Identified;
- Req 9. (Restrict Physical Access): Keep it Blocked;
- Req 10. (Log Everything): Keep It Identified;
- Req 11. (Test Regularly): Keep It Updated;
- Req 12. (InfoSec Policy): Keep it Identified;



FUNDAMENTALS

REQUIREMENT OVERVIEW

EXAMPLES

/01 POLICIES, EVERYWHERE

One of the most pervasive elements in the PCI DSS are policies. For anti-malware, configurations, user changes, software develop., access control, and others.

/02 MINIMIZING SCOPE

One of the most important things an organization can do is to minimize the scope of the CDE. This makes them have to comply in terms of less systems.

/03 COMPREHENSIVE & FULL

The PCI-DSS framework is a true cybersecurity tour de force, imposing checks on physical and logical access, system and network security, and all other aspects.

FUNDAMENTALS

REQUIREMENT OVERVIEW

KEY TAKEAWAYS

/01 COVERING ALL AREAS

The 12 requirements of the PCI-DSS framework cover all areas of cybersecurity from vulnerability scanning and protection, data encryption, access control, etc.

/02 COMPLEMENTARY

Many of the requirements are related, and complement themselves. Data storage and transmission, logical and physical access control, etc.